DOCTRACE / APPLICATION SECURITY ENGINEERING

Recueil des exigences de sécurité

Ingénierie des exigences de sécurité (SRE)

Produit	DocTrace — Plateforme de distribution de documents confidentiels
Référence	DOC-SRS-01
Version	1.6 · 8 novembre 2026
Architecture	React SPA/PWA · Jakarta EE 11 · WildFly 42 · Java 25
Cadre métier	CDC DocTrace v1.0 · Modules M1 à M6

Confidentialité · Intégrité · Disponibilité | Exigences testables et traçables

GESTION DOCUMENTAIRE

Identification et domaine d'application

Champ	Valeur
Référence	DOC-SRS-01
Version	1.6 — 08/11/2026
Document directeur	DocTrace — Cahier des charges v1.0
Document associé	Évaluation des risques et menaces (registre distinct)
Responsabilité	Équipe projet DocTrace

DocTrace organise la distribution de documents internes confidentiels. Chaque remise autorisée génère une copie marquée et associée à une preuve de distribution. Les exigences de sécurité ci-après couvrent les contrôles indispensables pour assurer l'accès légitime, la confidentialité des contenus, l'intégrité des copies et la traçabilité des opérations.

> **Objectifs de protection.** Les contrôles couvrent les accès documentaires, l'admission des fichiers, la distribution marquée, l'intégrité des preuves, la confidentialité des échanges et la continuité des opérations.

Organisation du recueil

Section	Objet
1	Démarche d'ingénierie des exigences de sécurité
2	Actifs et références fonctionnelles
3	Cas de mésusage et diagrammes de sécurité
4	Catalogue des exigences SR

1. Démarche d'ingénierie des exigences

Méthode SQUARE

Le recueil est établi selon une démarche SQUARE : cadrer les objectifs de sécurité, identifier les actifs et usages sensibles, construire des scénarios de mésusage, utiliser l'analyse des risques pour prioriser, puis formaliser et inspecter les exigences. Les cas de mésusage permettent de raisonner du point de vue adverse et les cas de sécurité décrivent les réponses attendues du système.

Étape	Activité	Résultat documentaire
1	Définitions	Termes partagés : document, copie, distributionId, preuve, autorisation, échec sûr.

Étape	Activité	Résultat documentaire
2	Actifs et objectifs	Inventaire des objets critiques et objectifs CIA par famille d'actifs.
3	Artefacts	CDC, architecture, matrice de droits, cas d'abus MU et diagrammes.
4	Risques	Scénarios MU transmis au registre de risques pour évaluation et classement.
5	Techniques d'élicitation	Revue du CDC, analyse des interfaces exposées, scénarios d'abus et revue collégiale.
6	Élicitation	Obligations SR dérivées des actifs, usages et scénarios d'abus.
7	Classification	Regroupement par contrôle d'accès, traitement, confidentialité, distribution, audit, exposition.
8	Priorisation	Criticité déterminée par l'exposition, l'impact CIA et le rôle du contrôle dans la livraison sûre.
9	Inspection	Cohérence, traçabilité, précision et vérifiabilité des exigences.

2. Périmètre fonctionnel et actifs à protéger

2.1 Acteurs et séparation des responsabilités

Rôle	Responsabilité autorisée
ADMIN	Gestion des identités, habilitations et politiques, sans accès implicite au contenu.
PUBLISHER	Publication et ACL sur ses documents.
READER	Catalogue et copies autorisés ; historique personnel.
AUDITOR	Analyse des fuites, accès aux traces et rapports ; pas de modification de documents.

2.2 Références aux fonctions métier

Les identifiants BF permettent de rattacher chaque exigence de sécurité aux fonctions correspondantes du cahier des charges DocTrace.

Identifiant	Fonction de référence	Module
BF-01	Permettre la connexion, la déconnexion et la consultation du profil utilisateur.	M1
BF-02	Gérer les comptes, rôles, habilitations et politiques de sécurité.	M1
BF-03	Administrer les catégories et niveaux de confidentialité.	M2
BF-04	Publier un document, en gérer l'importation et le statut.	M2
BF-05	Gérer les versions et l'archivage documentaire.	M2
BF-06	Définir, expirer et révoquer les ACL documentaires.	M2
BF-07	Consulter et rechercher les documents autorisés.	M2
BF-08	Générer et distribuer une copie marquée et enregistrée.	M3
BF-09	Insérer et vérifier une marque cachée dans un support PNG éligible.	M3
BF-10	Conserver les empreintes des originaux et des copies.	M3
BF-11	Analyser un fichier suspect et produire un rapport d'investigation.	M4

Identifiant	Fonction de référence	Module
BF-12	Consulter et vérifier les distributions, journaux et historiques.	M5
BF-13	Utiliser l'interface SPA/PWA installable, consulter les états de traitement et choisir FR/EN.	M6

2.3 Actifs et objectifs CIA

Actif	Désignation	Objectif principal
A-01	Versions originales et catalogue documentaire	Confidentialité / Intégrité
A-02	Copies distribuées et identifiants de remise	Intégrité / Confidentialité
A-03	Clés de chiffrement, stéganographie et signature	Confidentialité / Intégrité
A-04	Identités, jetons, rôles, habilitations et ACL	Confidentialité / Intégrité
A-05	Journaux d'audit, enregistrements de remise et rapports d'investigation	Intégrité / Confidentialité
A-06	Moteurs de traitement des documents et des images	Disponibilité / Intégrité
A-07	Métadonnées nominatives des distributions	Confidentialité / Intégrité

3. Cas de mésusage et objectifs de protection

Les scénarios ci-dessous dérivent de la surface d'attaque définie par l'architecture DocTrace. Ils servent à identifier les comportements à interdire, limiter ou détecter et à rattacher les contrôles attendus aux fonctionnalités du produit.

Cas	Scénario adverse	BF menacées	Contrôles SRE
MU-01	Manipulation d'identifiants et accès à un document d'autrui.	BF-06 / BF-07 / BF-08	SR-03 / SR-04
MU-02	Dépôt d'un fichier malveillant, déguisé ou trop coûteux à traiter.	BF-04	SR-06 / SR-07
MU-03	Saturation des imports, distributions ou investigations.	BF-04 / BF-08 / BF-11	SR-07 / SR-23
MU-04	Contournement du marquage ou émission d'une copie non conforme.	BF-08 / BF-10	SR-11 / SR-12 / SR-13 / SR-15 / SR-16
MU-05	Modification des droits, traces, clés ou preuves par un acteur privilégié.	BF-02 / BF-11 / BF-12	SR-03 / SR-08 / SR-16 / SR-18 / SR-24
MU-06	Vol de jeton, usurpation d'identité ou détournement de session.	BF-01	SR-01 / SR-02 / SR-09 / SR-22
MU-07	Falsification de marque et attribution erronée d'une fuite.	BF-08 / BF-11	SR-12 à SR-17
MU-08	Exposition de données via scripts, navigateur ou cache PWA.	BF-13	SR-02 / SR-10 / SR-20 / SR-21 / SR-22

3.1 Modèle global des cas d'abus

Le diagramme identifie les scénarios de mésusage MU-01 à MU-08, les acteurs adverses et les fonctions métier menacées au moyen de la relation « threatens ».

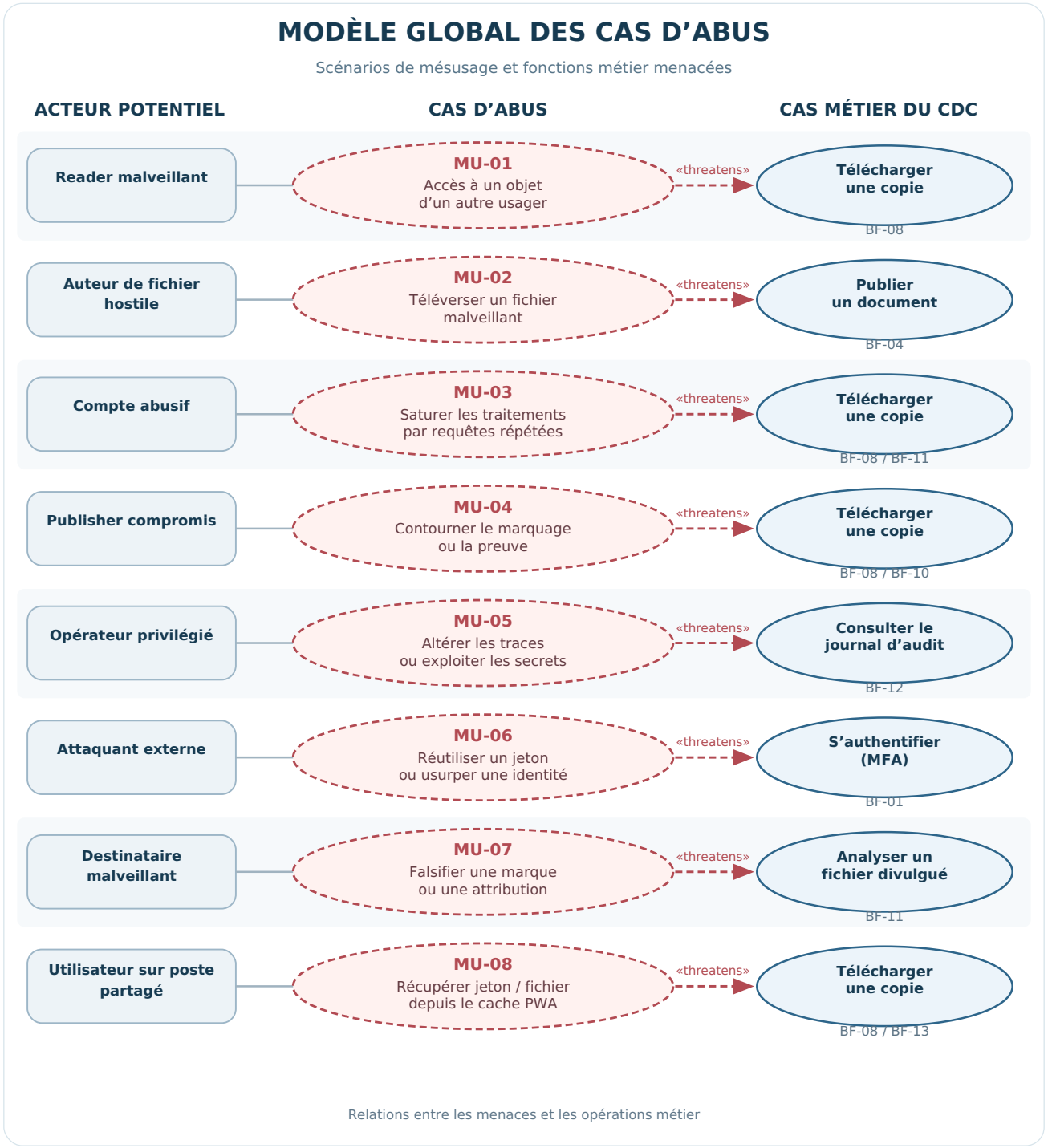


Figure SRE-01 — Cas d'abus globaux (MU-01 à MU-08) et fonctions métier menacées.

3.2 Cas métier, abus et mécanismes défensifs

La relation « threatens » matérialise une menace sur une opération métier ; « mitigates » désigne le comportement de sécurité destiné à l'atténuer. Les identifiants SR renvoient aux exigences du catalogue.

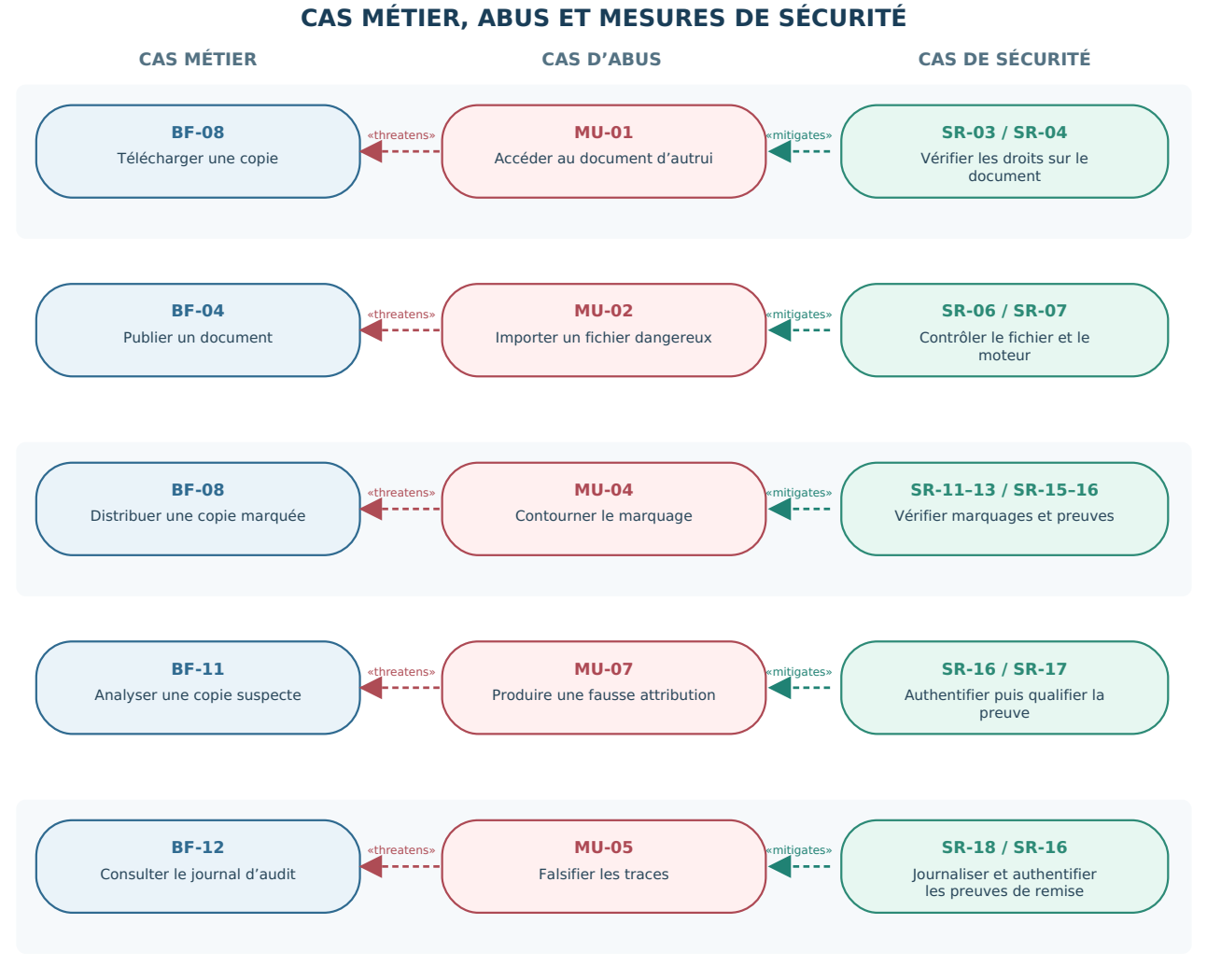


Figure SRE-02 — Cinq chaînes représentatives de protection ; les autres cas sont reliés dans le tableau MU.

4. Catalogue des exigences de sécurité

Les exigences ci-dessous fixent les contrôles de sécurité appliqués aux accès, aux fichiers, aux distributions, aux investigations et aux services associés. Chaque contrôle dispose d'un critère de vérification technique.

4.1 Délimitations et termes contrôlés

Terme	Définition applicable au catalogue
Document original	Suite d'octets de la version publiée, conservée chiffrée ; son SHA-256 est calculé avant chiffrement.
Copie finale	Suite d'octets après tous les marquages obligatoires et vérifications, avant émission HTTP.
« Émise »	État indiquant qu'une transmission autorisée a commencé côté serveur ; ne signifie pas réception intégrale côté navigateur.
Contrôle d'accès	Décision côté middleware fondée sur le rôle, la ressource, les ACL et la classification ; échec = refus.
Formats admis	Liste contrôlée par voie d'import et validée dans le CDC. Un format stockable n'est pas forcément distribuable.
Fichier de preuve	Fichier suspect importé pour investigation, distinct d'une version publiée et soumis à une liste d'admission dédiée.

4.2 — Identité et autorisations

SR-01 — Authentification forte et validation des jetons

Critique · C/I

Exigence. Toute API nécessitant une identité doit accepter uniquement un jeton d'accès émis par le realm Keycloak DocTrace et destiné à l'API DocTrace ; elle doit vérifier la signature avec une clé de confiance, l'algorithme autorisé, l'émetteur (iss), l'audience (aud), l'expiration (exp) et la date de validité (nbf lorsqu'elle existe). Toute connexion interactive doit être réalisée avec MFA. La modification des rôles ou habilitations, la gestion des clés et l'ouverture ou l'export d'une investigation doivent exiger une preuve vérifiable de MFA datant de cinq minutes au plus.

Justification. Empêcher l'usurpation d'identité, l'acceptation de jetons destinés à un autre service et l'exécution d'opérations critiques avec une authentification insuffisante.

Critère de vérification. Présenter des jetons à signature incorrecte, issu d'un autre realm, portant une autre audience, expirés ou non encore valables : chaque requête protégée est refusée. Pour les opérations sensibles, tester une authentification MFA de quatre puis six minutes : seule la première satisfait la condition de fraîcheur, sous réserve des permissions.

Fonctions : BF-01, BF-02, BF-11 **Abus :** MU-06

SR-02 — Sécurisation de la connexion SPA et des sessions

Élevée · C

Exigence. La SPA React doit utiliser OpenID Connect Authorization Code avec PKCE S256 auprès de Keycloak, sous un client public sans secret intégré au frontend. Les jetons d'accès et de rafraîchissement ne doivent pas être persistés dans localStorage, sessionStorage, IndexedDB ou Cache Storage. Les jetons doivent avoir une échéance, et les sessions doivent être clôturées à l'expiration de leur durée maximale, après la période d'inactivité configurée et à la déconnexion. La déconnexion doit supprimer les jetons détenus par la SPA et terminer la session Keycloak. Les jetons JWT autonomes non révoqués restent soumis à leur échéance.

Justification. Réduire le risque d'interception du code d'autorisation, d'exposition de secrets dans le frontend et de réutilisation des sessions.

Critère de vérification. Vérifier PKCE S256 et le refus d'un code_verifier incorrect ; contrôler l'absence de secret client dans les ressources React et l'absence de jetons dans les stockages persistants. Vérifier l'expiration d'un jeton et d'une session selon les durées configurées, la clôture de la session Keycloak et le comportement de l'API face à un JWT émis avant la déconnexion.

Fonctions : BF-01, BF-13 **Abus :** MU-06, MU-08

SR-03 — Séparation des rôles et protection des investigations

Critique · C/I

Exigence. Le middleware doit appliquer la matrice des permissions du CDC aux rôles ADMIN, PUBLISHER, READER et AUDITOR, indépendamment des restrictions de l'interface. ADMIN ne reçoit aucun droit implicite de lecture du contenu documentaire. Les fonctions d'analyse, les dossiers, les preuves déposées et les exports d'investigation doivent être accessibles uniquement à un AUDITOR explicitement habilité sur la ressource concernée ; aucun AUDITOR ne doit pouvoir modifier les originaux ni les traces d'audit. Les droits non explicitement accordés doivent être refusés.

Justification. Empêcher l'élévation de privilèges, l'accès transversal aux enquêtes et la confusion entre administration, publication et audit.

Critère de vérification. Exécuter une matrice d'essais API par rôle et par ressource, dont ADMIN→lecture document, READER→investigation, PUBLISHER→export d'enquête, AUDITOR→altération d'original ou journal et AUDITOR non habilité→dossier d'un tiers ; vérifier les refus et la journalisation des accès sensibles.

Fonctions : BF-02, BF-03, BF-11, BF-12 **Abus :** MU-01, MU-05, MU-07

SR-04 — Autorisation au niveau des documents

Critique · C

Exigence. Avant toute consultation de métadonnées, recherche, accès à une version ou émission de copie, l'API doit décider l'autorisation pour l'utilisateur authentifié et le document demandé à partir de la matrice des rôles, des droits du propriétaire selon le CDC, des ACL actives et non révoquées et du niveau d'habilitation. Les résultats de recherche et les métadonnées doivent être filtrés selon la même décision. Un identifiant de document, une URL ou une identité déclarée par le client ne confère aucun droit.

Justification. Prévenir BOLA/IDOR, la fuite de métadonnées et le contournement des règles d'accès par manipulation d'identifiants.

Critère de vérification. Tester un document autorisé puis un autre document avec identifiant substitué ; répéter avec ACL expirée, permission révoquée et habilitation insuffisante ; vérifier le refus côté API et l'absence de document ou métadonnée dans les résultats de recherche.

Fonctions : BF-05, BF-06, BF-07, BF-08 **Abus :** MU-01

4.3 — Sécurité des fichiers

SR-06 — Contrôle et admission des fichiers importés

Critique · I/A

Exigence. Chaque opération d'import doit accepter uniquement les formats autorisés pour sa fonction et vérifier la taille, le type réel et la structure du fichier avant sa prise en charge. Pour les versions publiées au catalogue, la taille ne doit pas dépasser 50 Mo et une analyse antivirus favorable doit précéder la publication. Tout fichier non conforme, détecté comme malveillant, non analysable ou soumis pendant une indisponibilité de l'antivirus doit rester inaccessible et ne pas être publié. Un fichier admis au stockage ne peut être distribué avec marquage que si un procédé de marquage est défini pour son format.

Justification. Empêcher l'introduction de contenus hostiles et éviter d'assimiler « fichier stockable » à « fichier distribuable ».

Critère de vérification. Tester un fichier conforme, un format interdit, un fichier déguisé, un fichier corrompu, un fichier dépassant 50 Mo, le fichier de test EICAR et une indisponibilité de l'antivirus. Aucune entrée non conforme ne doit atteindre l'état « publiée ». Vérifier que les formats sans procédé de marquage pris en charge sont refusés à l'étape de distribution.

Fonctions : BF-04, BF-11 **Abus :** MU-02

SR-07 — Sécurisation du traitement des fichiers

Critique · I/A

Exigence. Les opérations d'analyse, de transformation et de marquage doivent appliquer aux fichiers les contrôles correspondant à leur format : validation structurelle, rejet des fonctions actives interdites et contrôle des volumes décodés lorsque nécessaire. Chaque tâche doit être exécutée avec des limites configurées de mémoire et de durée ; leur dépassement doit interrompre le traitement. Les fichiers temporaires doivent rester inaccessibles aux utilisateurs, et aucun fichier incomplet ou non vérifié ne doit être publié ou préparé pour distribution.

Justification. Limiter l'exploitation des parseurs et décodeurs, les décompressions abusives et les résultats incohérents.

Critère de vérification. Soumettre des fichiers malformés, des PDF comportant des fonctions interdites et des contenus dépassant volontairement les limites de traitement configurées. Vérifier l'arrêt contrôlé, l'isolation ou la suppression des fichiers temporaires et l'absence de résultat partiel accessible.

Fonctions : BF-04, BF-08, BF-11 **Abus :** MU-02, MU-03

4.4 — Confidentialité et cryptographie

SR-08 — Chiffrement des originaux et séparation des clés

Critique · C/I

Exigence. Chaque version originale doit être chiffrée au repos avec AES-256-GCM avant son stockage définitif. Un nonce de 96 bits ne doit jamais être réutilisé avec une même clé et le tag GCM de 128 bits doit être vérifié avant toute utilisation du contenu déchiffré. Les clés de chiffrement doivent être conservées hors du stockage documentaire, accessibles uniquement à l'identité technique autorisée et utilisables pour restaurer les versions sauvegardées.

Justification. Rendre inexploitable une copie brute du stockage sans accès aux clés, et détecter les altérations du chiffré.

Critère de vérification. Lire le stockage sans clé, tenter un déchiffrement sans autorisation et modifier un octet du chiffré : le contenu n'est pas révélé et l'altération est rejetée. Vérifier séparément la configuration du gestionnaire de clés et l'unicité des nonces sur un échantillon de chiffrement.

Fonctions : BF-04, BF-05, BF-08 **Abus :** MU-05

SR-09 — Protection des communications sensibles

Élevée · C/I

Exigence. Les interfaces exposées transportant des identifiants, jetons, documents ou métadonnées sensibles doivent imposer HTTPS avec TLS 1.3 et certificat vérifiable. Aucun identifiant ni document ne doit être reçu ou émis via HTTP non chiffré. Les connexions entre le middleware et les composants internes véhiculant des données sensibles doivent employer un canal authentifié et chiffré, selon la configuration de déploiement approuvée.

Justification. Empêcher l'interception et l'altération des données en transit, y compris entre composants internes.

Critère de vérification. Tenter des requêtes HTTP vers l'API et des connexions TLS à certificat invalide ; contrôler qu'aucune donnée sensible n'est transmise. Vérifier les sessions TLS des flux navigateur–Keycloak, navigateur–API, API–base et API–services de clés.

Fonctions : BF-01, BF-08, BF-11 **Abus :** MU-06

SR-10 — Minimisation et conservation des données de traçabilité

Élevée · C

Exigence. Les journaux techniques, historiques de distribution et rapports d'investigation doivent conserver uniquement les informations nécessaires à leur finalité. Les journaux techniques ne doivent contenir ni mots de passe, ni jetons, ni clés cryptographiques, ni contenu documentaire intégral. Les éléments probants nécessaires aux investigations doivent être protégés par les autorisations définies en SR-03. Chaque catégorie de données de traçabilité doit respecter une durée de conservation définie dans la politique du système ; à son terme, les données doivent être supprimées, sauf obligation de conservation applicable.

Justification. Limiter les fuites secondaires et la conservation excessive de données personnelles ou confidentielles.

Critère de vérification. Inspecter les journaux générés après connexion, distribution, refus et investigation ; confirmer l'absence de secrets et de documents intégraux. Pour chaque catégorie, vérifier la suppression des données ayant dépassé la durée de conservation définie et le maintien des seules données couvertes par une exception justifiée.

Fonctions : BF-08, BF-11, BF-12 **Abus :** MU-05, MU-08

4.5 — Distribution et marquage

SR-11 — Vérification d'intégrité des versions originales

Critique · I

Exigence. À chaque publication d'une version, DocTrace doit calculer et enregistrer SHA-256 sur les octets du document original avant chiffrement. Avant de préparer une copie à distribuer, il doit recalculer SHA-256 sur les octets déchiffrés et comparer la valeur à celle enregistrée pour cette version. Toute divergence doit interdire la distribution et produire un événement d'audit.

Justification. Détecter les altérations non cohérentes avec la version publiée, avant insertion d'un marquage.

Critère de vérification. Publier un document, altérer le chiffré ou remplacer le document sauvegardé et tenter une distribution ; vérifier le refus et l'événement. Vérifier une version intacte comme cas positif. L'empreinte seule ne garantit pas l'authenticité d'une référence modifiable par un même attaquant.

Fonctions : BF-05, BF-08, BF-10 **Abus :** MU-04

SR-12 — Watermark des copies PDF par distribution

Critique · I

Exigence. Chaque PDF destiné à être distribué doit comporter sur chaque page une marque visible associant la copie à son destinataire et à son identifiant de distribution, ainsi qu'une marque discrète contenant cet identifiant. Le marquage visible doit être répété sur au moins trois zones lorsque la mise en page le permet, conformément au CDC. Le service doit vérifier sur le PDF final la présence des marques prescrites ; un PDF dont les marques requises manquent ne peut pas être émis.

Justification. Permettre une distinction des copies distribuées et une recherche ultérieure d'identifiant.

Critère de vérification. Générer des PDF d'une et plusieurs pages pour deux destinataires ; contrôler marques et identifiants sur chaque page, y compris la discrète, puis provoquer un échec d'insertion ; aucune copie sans marques requises ne doit être émise.

Fonctions : BF-08 **Abus :** MU-04, MU-07

SR-13 — Stéganographie vérifiée dans les images compatibles

Critique · I/C

Exigence. Pour chaque image PNG embarquée et éligible au procédé défini dans le CDC (capacité contrôlée, dimensions au moins 128 × 128 pixels), le moteur doit insérer dans les pixels une charge contenant l'identifiant de distribution, chiffrée et authentifiée avec AES-256-GCM, puis réussir à l'extraire du document final. L'absence d'image éligible doit produire le statut « non applicable » sans constituer un échec. Si une image identifiée comme éligible ne peut pas être marquée ou relue authentiquement, la copie ne doit pas être émise.

Justification. Assurer une trace cachée authentifiable lorsque le support réellement disponible le permet, sans la confondre avec une métadonnée.

Critère de vérification. Tester une image PNG éligible, une image de taille insuffisante, un PDF sans PNG éligible et un identifiant altéré ; vérifier respectivement extraction authentifiée, statut non applicable, statut non applicable et impossibilité d'attribution. Simuler un échec de marquage sur une image éligible : émission refusée.

Fonctions : BF-08, BF-09 **Abus :** MU-04, MU-07

SR-15 — Contrôles préalables, unicité et empreinte de distribution

Critique · I

Exigence. Chaque opération de distribution doit recevoir un identifiant unique. Avant de commencer à transmettre une copie, le middleware doit avoir validé l'autorisation d'accès, l'intégrité de l'original, l'application et la vérification des marques obligatoires (ou leur non-applicabilité selon le format), le SHA-256 exact du fichier final et la création d'un enregistrement de distribution authentifié associant document, version, destinataire, horodatage, empreinte et état. L'échec de l'un de ces contrôles doit interdire toute émission documentaire et produire un état « échec ». L'état « émise » signifie uniquement que le serveur a commencé le transfert autorisé, sans attester la réception complète par le navigateur.

Justification. Garantir l'unicité, la traçabilité et la conformité de chaque copie émise, sans diffuser un document dont les contrôles obligatoires ont échoué.

Critère de vérification. Effectuer deux distributions de la même version et vérifier la différence des identifiants. Recalculer l'empreinte sur la copie obtenue après une transmission complète. Provoquer successivement un refus d'autorisation, une altération de l'original, un échec de marquage, un défaut d'empreinte et un échec d'enregistrement : aucun octet documentaire ne doit être émis et l'état ne doit pas être « émise ».

Fonctions : BF-08, BF-10 **Abus :** MU-04, MU-07

SR-16 — Authenticité cryptographique des preuves de distribution

Critique · I

Exigence. Avant l'utilisation d'un enregistrement de distribution comme preuve technique, DocTrace doit vérifier un code d'authentification HMAC-SHA-256 calculé sur une sérialisation canonique des champs obligatoires (distributionId, version, destinataire, date, empreinte, état). La clé HMAC doit être distincte de la clé de chiffrement des documents et inaccessible aux utilisateurs. Tout enregistrement dont l'authentification échoue doit être rejeté pour l'attribution et donner lieu à une alerte d'intégrité.

Justification. Empêcher la modification silencieuse des associations entre destinataires, copies et événements de remise.

Critère de vérification. Modifier séparément chaque champ authentifié, supprimer le code HMAC ou vérifier avec une autre clé : la vérification doit échouer et la preuve doit être exclue de l'attribution. Une preuve non modifiée avec un HMAC valide doit être acceptée.

Fonctions : BF-08, BF-11, BF-12 **Abus :** MU-04, MU-05, MU-07

SR-17 — Qualification prudente des résultats d'investigation

Critique · I

Exigence. L'investigation doit classer chaque résultat dans l'un des états suivants : « correspondance exacte avec une copie enregistrée et authentifiée », « marque authentifiée et identifiant retrouvé » ou « preuve insuffisante ». Le rapport doit mentionner la méthode, le niveau de confiance associé et toute impossibilité de vérification. L'identification d'une distribution ne doit jamais être présentée comme preuve certaine de l'auteur humain de la fuite.

Justification. Éviter une attribution personnelle erronée et rendre les limites des indices lisibles dans les rapports.

Critère de vérification. Tester une copie identique, une copie transformée avec marque encore vérifiable, une charge forgée et un document sans marque ; vérifier les quatre résultats attendus et les avertissements sur l'attribution humaine.

Fonctions : BF-11 **Abus :** MU-07

4.6 — Audit et traçabilité

SR-18 — Journalisation contrôlée des opérations sensibles

Élevée · I

Exigence. Les changements de rôle et d'ACL, publications, distributions, refus d'accès, échecs de traitement ou de marquage et opérations d'investigation doivent produire un événement horodaté avec type, identifiant d'acteur, identifiant d'objet, résultat et identifiant de corrélation. Les interfaces applicatives ne doivent fournir aucune opération de modification ou de suppression de ces événements. L'accès à leur consultation doit respecter SR-03 et leur contenu SR-10.

Justification. Permettre la reconstitution des opérations critiques tout en limitant les modifications via l'application.

Critère de vérification. Exécuter les opérations sensibles autorisées et refusées, puis vérifier les champs et événements attendus. Tenter la modification ou la suppression des traces via chaque rôle applicatif : les API doivent refuser toutes ces opérations. Vérifier l'absence de secrets dans les événements.

Fonctions : BF-02, BF-04, BF-06, BF-08, BF-11, BF-12 **Abus :** MU-05

4.7 — Interface web et exploitation

SR-20 — Validation des API et prévention des injections

Élevée · C/I

Exigence. Le middleware doit vérifier pour chaque entrée API le type, le format, la taille, les valeurs autorisées et les règles métier applicables, avant tout accès aux données. Toute interaction SQL doit employer des requêtes paramétrées. L'interface doit encoder les données non fiables selon le contexte d'affichage ; elle ne doit pas injecter directement du HTML non nettoyé. Les réponses d'erreur adressées au client ne doivent divulguer ni pile d'exécution, ni secret, ni chaîne de connexion. Une CSP explicite doit limiter les sources de scripts aux sources approuvées.

Justification. Prévenir les injections, l'exécution de scripts malveillants dans la SPA et les fuites d'informations techniques.

Critère de vérification. Injecter des chaînes SQL et HTML/JavaScript dans recherches, métadonnées, paramètres de pagination et identifiants ; vérifier refus ou traitement comme données, absence d'exécution script, CSP active et réponses sans détails internes.

Fonctions : BF-03, BF-06, BF-07, BF-13 **Abus :** MU-01, MU-08

SR-21 — Non-mise-en-cache des données sensibles dans la PWA

Élevée · C

Exigence. Le service worker doit limiter Cache Storage aux ressources statiques non sensibles de la SPA. Aucun document, réponse API confidentielle ou jeton ne doit être persisté par l'application dans Cache Storage, IndexedDB, localStorage ou sessionStorage. Les réponses documentaires et API sensibles doivent porter la directive HTTP Cache-Control: no-store et être exclues des stratégies de cache de la PWA.

Justification. Empêcher que l'application conserve silencieusement du contenu confidentiel sur un poste partagé.

Critère de vérification. Télécharger une copie, consulter les métadonnées, se déconnecter puis inspecter Cache Storage et les autres stockages de l'origine, en ligne et hors connexion ; aucune réponse sensible mise en cache par l'application ne doit être présente. Vérifier les en-têtes HTTP no-store.

Fonctions : BF-08, BF-13 **Abus :** MU-08

SR-22 — Protection des origines et des services exposés

Élevée · C/I

Exigence. L'API publique doit configurer CORS avec une liste explicite des origines autorisées ; l'origine non reconnue ne doit pas recevoir une autorisation CORS. Si l'API accepte des cookies comme preuve d'authentification, les opérations modifiant l'état doivent appliquer une protection CSRF vérifiable ; avec des jetons Bearer explicites et sans authentification par cookie, aucun cookie ne doit accorder d'accès API. Les consoles WildFly, bases de données et interfaces internes de gestion ne doivent pas être directement accessibles depuis la zone Internet.

Justification. Réduire les accès intersites abusifs et la surface d'attaque des composants d'administration.

Critère de vérification. Tester une origine autorisée et une non autorisée ; en cas d'authentification par cookie, tester une requête intersite de modification d'état sans jeton CSRF valide ; depuis l'extérieur, tester l'inaccessibilité des ports et consoles internes.

Fonctions : BF-01, BF-02, BF-13 **Abus :** MU-06, MU-08

SR-23 — Quotas et disponibilité des traitements

Critique · A/I

Exigence. Les opérations d'import, de distribution et d'investigation doivent être soumises à des quotas et limites de débit par acteur. Les tâches coûteuses doivent passer par une file d'attente de capacité bornée et respecter un nombre maximal d'exécutions simultanées. Une requête excédant l'un de ces plafonds doit être refusée sans lancement de tâche supplémentaire. Les tâches interrompues lors du traitement des fichiers, conformément à SR-07, doivent libérer leurs ressources et leurs fichiers temporaires.

Justification. Préserver le service en cas de requêtes répétitives ou de charge simultanée et maintenir un comportement prévisible lors des refus.

Critère de vérification. Effectuer des requêtes dépassant successivement les quotas, le débit autorisé, le nombre maximal de tâches simultanées et la capacité de file configurés ; contrôler les refus (HTTP 429 pour les quotas et le débit), l'absence de tâches supplémentaires et la reprise de capacité après interruption. Les limites de décodage et de durée propres à un fichier sont testées au titre de SR-07.

Fonctions : BF-04, BF-08, BF-11 **Abus :** MU-03, MU-04

SR-24 — Sauvegarde et restauration vérifiée

Élevée · A/I

Exigence. DocTrace doit disposer de sauvegardes chiffrées accessibles uniquement aux comptes de restauration habilités et conservées séparément du stockage actif. Elles doivent permettre une restauration cohérente des originaux chiffrés, des métadonnées et ACL, des enregistrements de distribution, des journaux et des clés nécessaires au déchiffrement. Une procédure de restauration doit vérifier la cohérence des références, les empreintes et la possibilité d'un déchiffrement autorisé.

Justification. Éviter qu'une panne ou une restauration incomplète rende les documents ou les historiques de distribution inutilisables.

Critère de vérification. Restaurer une sauvegarde en environnement isolé, vérifier la correspondance des documents, versions, ACL et distributions, recalculer les empreintes et déchiffrer un document avec une clé restaurée de manière autorisée. Tout ensemble incohérent doit être signalé et non réutilisé en production.

Fonctions : BF-05, BF-12 **Abus :** MU-05